SEGURIDAD INFORMÁTICA & DIAGNÓSTICO

Auditoría y Mitigación de Vulnerabilidades Críticas SAP

Resumen Ejecutivo
Informe técnico derivado del análisis de seguridad y revisiones **EarlyWatch Alert**, orientado a subsanar brechas críticas de autorización, accesos irrestrictos y riesgos de segregación de funciones. Se recomienda la atención modular de los hallazgos mediante solicitudes (tickets) individuales para acelerar las correcciones de menor complejidad.

1. Metodología de Remediación Modular por Tickets

Con el objetivo de agilizar la mitigación de riesgos sin paralizar la operación diaria, se propone un esquema de trabajo por requerimientos independientes:

- **Tratamiento Individualizado:** Cada vulnerabilidad detectada se gestiona como una unidad de trabajo independiente con su propio ciclo de prueba y validación.
- **Desacoplamiento de Complejidad:** Permite aplicar soluciones inmediatas a fallos críticos de resolución rápida (ej. revocación de permisos de Debugging en PRD) sin depender de proyectos de rediseño de roles de mayor duración.

2. Matriz de Vulnerabilidades Detectadas y Plan de Corrección

Área / Hallazgo	Riesgo Identificado	Recomendación Técnica
Usuarios Estándar / Defecto	Acceso no autorizado mediante credenciales por defecto.	Modificar contraseñas, aplicar bloqueos y ajustar autorizaciones.
Superusuarios (SAP_ALL / SAP_NEW)	Modificación irrestricta de configuraciones y datos del negocio.	Retirar perfiles amplios y asignar roles específicos por puesto.
Acceso Directo a Tablas	Visualización o alteración no autorizada de datos sensibles.	Restringir el acceso a tablas mediante objetos de autorización.
Ejecución de Programas	Salteo de la verificación inicial de transacciones (S_TCODE).	Acotar autorizaciones para impedir la ejecución de reportes fuera de función.
Permisos de Debugging	Alteración de memoria en ejecución y evasión de controles.	Eliminar permisos de Debugging en ambiente productivo (PRD).
Gestión de Impresiones (Spool)	Visualización de spools de impresión con datos confidenciales.	Restringir autorizaciones de visualización de spools.
Conexiones RFC	Acceso no autorizado a sistemas remotos e interfaces.	Ajustar roles que administran RFCs a personal autorizado.
Blanqueo de Claves	Cambio no autorizado de contraseñas de usuarios.	Restringir la función exclusivamente al equipo de administración de seguridad.
Segregación de Funciones (SoD)	Incompatibilidad de funciones (ej. autorizar pagos y crear OC).	Eliminar combinaciones de riesgo e implementar roles por puesto.

3. Priorización de la Ejecución

- **Fase 1 (Inmediata - 24 a 48 hs):** Eliminación de permisos de Debugging en PRD, cambio de claves estándar y restricción de blanqueo de contraseñas.
- **Fase 2 (Corto Plazo - 1 a 2 semanas):** Ajuste de autorizaciones S_TABU_DIS (acceso a tablas) y segregación en gestión de spools.
- **Fase 3 (Mediano Plazo):** Depuración completa de `SAP_ALL` e implementación del modelo de roles por puesto de trabajo.